

SOC 2 TYPE I READINESS & GAP ANALYSIS REPORT

Target Environment: FinTech Go Inc. | Framework: AICPA SOC 2 Security Criteria

Target Entity: FinTech Go Inc.	Assessment Type: SOC 2 Type I Readiness Review
Prepared By: Lead GRC Consultant	Scope Standard: AICPA TSC CC6.1, CC6.2, CC7.3, CC7.4, CC8.1, CC9.2
Assessment Date: August 2026	Overall Status: Remediations Required Prior to Audit

EXECUTIVE SUMMARY

FinTech Go Inc. engaged GRC consulting services to conduct a comprehensive SOC 2 Type I readiness assessment across its AWS production environment, development workflows, third-party software integrations, and operational procedures. The objective was to identify existing control gaps against the AICPA Trust Services Criteria (Security) and define actionable remediation steps prior to engaging an external CPA firm for formal audit testing.

DETAILED GAP ANALYSIS & ASSESSMENT FINDINGS

1. Access Control & Identity Management (SOC 2 CC6.1, CC6.2)

Identified Gap: 30 developers possess persistent root AWS access; absence of enforced Multi-Factor Authentication (MFA) and Single Sign-On (SSO) integration across production infrastructure.

Risk Severity: CRITICAL

Remediation Plan: Lock AWS root credentials. Implement AWS IAM Identity Center mapped to Google Workspace SSO with mandatory WebAuthn/MFA. Restrict developers to Role-Based Access Control (RBAC) with Least Privilege permissions.

Audit Evidence Required: IAM Identity Center configuration exports, Google Workspace MFA enforcement logs, CloudTrail access logs.

2. Change Management & Software Deployment (SOC 2 CC8.1)

Identified Gap: Developers execute manual terminal deployments (`kubectl apply`) directly from local laptops to the EKS production cluster, bypassing code reviews, automated tests, and segregation of duties.

Risk Severity: HIGH

Remediation Plan: Mandate GitHub branch protection rules requiring at least 1 peer approval on Pull Requests. Build an automated CI/CD pipeline (GitHub Actions) for build, SAST, and unit testing. Restrict deployment credentials exclusively to automated CI/CD service roles.

Audit Evidence Required: GitHub branch protection rule configuration screenshots, sample PR audit logs (reviewers, timestamps, build statuses).

3. Third-Party Vendor Risk Management (SOC 2 CC9.2)

Identified Gap: Critical third-party SaaS vendors (OpenAI, FastAuth KYC, Twilio) were onboarded without due diligence, security assessments, or formal Data Processing Agreements (DPAs) covering customer PII/financial data.

Risk Severity: HIGH

Remediation Plan: Establish a formal Vendor Management Policy and Inventory Register. Execute DPAs with zero data-retention clauses with OpenAI and FastAuth. Collect annual SOC 2 Type II or ISO 27001 audit reports for all critical vendors.

Audit Evidence Required: Populated Vendor Inventory Register, executed DPAs, archive of vendor SOC 2 reports.

4. Incident Response & Business Continuity (SOC 2 CC7.3, CC7.4)

Identified Gap: PostgreSQL database relies on manual, ad-hoc snapshots taken every few weeks without RPO/RTO metrics. Absence of a formal Incident Response Plan (IRP) or central log monitoring.

Risk Severity: MEDIUM

Remediation Plan: Enable AWS RDS Automated Backups (35-day point-in-time recovery) and Multi-AZ replication. Document a formal Incident Response Plan with defined severity levels and escalation paths. Route system logs to an automated SIEM/alerting platform.

Audit Evidence Required: Documented Incident Response Plan, annual tabletop exercise write-up, RDS backup configuration and restoration test logs.

REMEDIATION TRACKING & TIMELINE

Control Domain	Primary Remediation Action	Owner	Target Completion
Access Control	AWS SSO + MFA Rollout & Root Lockdown	DevOps / Security	Week 2
Change Control	GitHub Branch Rules & CI/CD Pipeline Setup	Lead Software Engineer	Week 3
Vendor Risk	Vendor Inventory & DPA Execution	Operations / Legal	Week 4
Disaster Recovery	RDS Multi-AZ Setup & IRP Document Draft	Infrastructure Lead	Week 5